

firm-bot — Investor One-Pager

Mine-FNL

firm-bot — Investor One-Pager

Mine-FNL · September 2026 · MIT-licensed open source Live preview: <https://firm-bot.vercel.app>
Repository: <https://github.com/Mine-FNL/firm-bot>

The problem

Cloud-based RAG products — Harvey, Spellbook, Glean, ChatGPT Enterprise — have changed how legal, audit, and consulting firms read their own documents. They have not changed who reads them.

Every cloud vendor adds at least one, usually several, subprocessors to the chain of custody of the most sensitive work product a firm does: contracts, transaction documents, engagement letters, audit working papers, opinion letters, board materials.

For some firms this is fine. For a non-trivial subset — any firm handling matters that touch attorney-client privilege, GDPR-regulated personal data, HIPAA protected health information, government classified material, or matters under a protective order — the vendor's presence is disqualifying.

This is a real, non-niche problem. It is also the same problem across ~80% of the firms who would benefit from RAG and have decided they cannot use the cloud products.

The product

firm-bot is a citation-required, local-first RAG chatbot builder for professional services firms. MIT-licensed. Runs entirely on the firm's hardware.

- **Three commands from clone to running:**

```
pip install --extra-index-url https://mine-fnl.github.io/firm-bot/simple/ firm-bot
firm-bot demo init
firm-bot serve
```

- **No cloud calls during operation.** All inference, embedding, retrieval, and audit logging happens locally. Ollama auto-pulls the configured model on first boot.
- **Citation-required by default.** Every claim anchored to [file:page] with an LLM-as-judge that flags ungrounded answers.
- **Structure-aware chunker.** Recognises Article §, Section, Title Case, ALL CAPS, WHEREAS preambles. +1.7pp precision@k vs naive sliding window on a 30-contract corpus (reproducible via `make bench-compare`).

- **STRIDE threat model published** in `SECURITY.md`. Per-IP rate limit, body cap, CORS allow-list, opt-in API key auth, per-firm filesystem isolation.
 - **Per-firm query audit log** — append-only JSONL with retention, SIEM-friendly export (CSV/JSON/JSONL/Markdown). Never logs the question or answer text — only their SHA-256 hashes.
-

The market

TAM estimate (conservative):

- US legal services: ~\$400B revenue
- US audit & accounting: ~\$200B revenue
- US management consulting: ~\$350B revenue
- Roughly 35-45% of these firms have a use case for RAG over their internal documents.
- Of those, roughly 15-25% cannot use cloud RAG due to compliance posture. That subset is firm-bot's beachhead.

Beachhead sizing:

- ~\$70B annual revenue × 15-25% × estimated 10% RAG-budget allocation = **~\$1-1.8B annual addressable spend** in the US alone.

Why now:

1. Open-weight LLMs are good enough. qwen2.5-coder:14B on commodity hardware matches GPT-3.5-class quality at the answer granularity legal/audit work needs.
 2. Local-first has become operationally credible. Ollama, Chroma, sentence-transformers all ship with one-command install on commodity hardware.
 3. The compliance gap is widening as more firms move from "we'd love to use AI but the audit is too painful" to "we want AI for X specific use case but it has to be local-first."
-

What's shipping today (v0.1.1)

- **Multi-tenant storage** with per-firm filesystem isolation
- **PDF/EML/DOCX ingest** with OCR fallback and incremental indexing
- **Structure-aware chunker** (regex cascade over Article/Section/Title Case/ALL CAPS/WHEREAS)
- **Hybrid retrieval** (BM25 + dense via RRF) with opt-in cross-encoder reranker
- **Citation-required prompts** + 7B LLM-as-judge guard
- **Streaming SSE** on `/query/stream`
- **Prometheus /metrics** + structured JSON logs + per-stage timing
- **Per-IP rate limit, body cap, CORS allow-list, log redaction**
- **RAGAS-style quality metrics** (faithfulness, answer relevancy, context precision, context recall)
- **Concurrent load benchmark** (p50/p95/p99)
- **Per-firm query audit log** + SIEM export
- **Optional API key auth** (Bearer / X-API-Key)

- **CUAD subset benchmark** with reproducible script
- **docker-compose** for one-command full-stack deployment
- **GitHub Pages-hosted PEP 503 simple index** for `pip install` without PyPI publisher approval

Engineering baseline (CI-enforced):

- 196 unit tests passing (was 0 at start of project)
 - 74.70% line coverage floor
 - `mypy --strict clean` (49 source files)
 - `ruff clean` (production code)
 - CI: lint + typecheck + tests matrix (ubuntu-latest, macos-latest × Python 3.11/3.12/3.13) + weekly benchmark regression gate + Docker compose smoke test
-

What's not shipping today (honest)

- **Per-user authentication.** The opt-in API key middleware is a single shared-secret gate. Per-user auth (login, sessions, OAuth/OIDC) requires deploying behind `oauth2-proxy` or similar. v0.2 milestone.
- **RBAC.** All callers with a valid key can act on any firm. Tenant isolation is filesystem-level. v0.2 milestone.
- **Prompt injection defence.** Ingested content is not sanitised for prompt-injection patterns. v1.0 milestone.
- **70B-tier model benchmarks.** Default tier is 7B / 14B. v0.3.
- **Domain packs** (litigation, M&A, regulatory compliance, audit working papers). v0.4.
- **HA topology** (active/active, document version tracking). v1.0.

The `WHITEPAPER.md` ships with the full roadmap.

Go-to-market

Three channels, in order of speed-to-impact:

1. **Cold outbound to compliance officers / vendor-risk reviewers** at target firms. Templates ready in `OUTREACH.md`.
2. **Show HN / Twitter / Reddit** (r/LocalLLaMA, r/Python, r/legaltech). Copy ready in `MARKETING.md`, `TWEETS.md`, `ARTICLE_DEVTO.md`, `ARTICLE_BLOG.md`, `PRODUCT_HUNT.md`, `INDIE_HACKERS.md`.
3. **Conference presence.** LegalTech, ILTACON, Legalweek. Whitepaper ready as a leave-behind.

No paid acquisition. The marketing budget is engineering hours on making the repo maximally credible to a vendor-risk reviewer.

Pricing model

Open source is the wedge. Revenue comes from two streams:

1. **Support contracts.** \$5k-\$25k/year/firm for the first 5 firms, scaling with the number of firms deployed.
2. **Compliance attestations.** Quarterly SOC 2 / ISO 27001 evidence pack for firms whose vendor-risk teams require it. \$10k-\$50k per assessment cycle, depending on firm size.

This is a deliberately modest monetization model. The product is intentionally self-hostable; the value capture is in the compliance certification work, not the license.

What we're asking for

\$500k-\$1M seed to fund:

1. **Engineering** — Two senior engineers for 12 months to land v0.2-v0.4 (auth, RBAC, prompt-injection defence, 70B-tier benchmarks, domain packs).
2. **Compliance certifications** — SOC 2 Type I and ISO 27001 certification, so the support contracts can carry real weight.
3. **GTM** — Conference presence, content production, the first 25 pilot firms.

What we are NOT asking for:

- A pivot to "AI for lawyers" SaaS. This stays open source.
 - A massive team. Five people can run this for the first two years.
 - A GPU cloud. Customers bring their own.
-

Why this is fundable

1. **Real revenue path.** Support contracts in this segment close quickly once compliance is signed off.
 2. **Defensible moat.** The compliance certification is the moat — anyone can fork the code, but the SOC 2 Type II report takes 12 months and costs \$200k+.
 3. **Network effects.** Each deploying firm produces a per-firm audit log that becomes reference material for the next firm.
 4. **Aligned with the open-weight AI thesis.** We're building on qwen2.5 / llama / etc. The model's quality improvement is *someone else's research budget*. We benefit without paying for it.
-

Team

Mine-FNL is an open-source contributor collective focused on local-first AI infrastructure for professional services. The firm-bot project is the collective's flagship project as of September 2026.

The team has shipped:

- The codebase described above (v0.1.1)
- A 5,300-word whitepaper

- Six marketing artifacts (whitepaper, Dev.to, blog, 3 tweet threads, Product Hunt, IndieHackers — 12,548 words total)
 - Live landing page at <https://firm-bot.vercel.app>
 - Distribution via GitHub Releases + PEP 503 simple index
 - Reproducible benchmark infrastructure
 - CI matrix (lint, typecheck, tests × Python version × OS, Docker smoke test, weekly regression gate)
-

Contact

- **GitHub:** <https://github.com/Mine-FNL/firm-bot>
- **Discussions:** <https://github.com/Mine-FNL/firm-bot/discussions>
- **Issues:** <https://github.com/Mine-FNL/firm-bot/issues>
- **Live preview:** <https://firm-bot.vercel.app>

— Mine-FNL · September 2026 · MIT